

(c) Narrativa explicativa de la Encuesta ISO/IEC 42001 – Ciberseguridad y Gestión de IA

1. De la magia a la medida

Durante años, la inteligencia artificial ha vivido cómodamente instalada en el terreno de la magia: modelos que “aprenden”, sistemas que “intuyen”, algoritmos que “descubren patrones” con lustre casi esotérico. La Norma ISO/IEC 42001 llega, impertinente, a recordarnos que detrás de tanta metáfora hay sistemas de información que manejan datos delicados, que toman decisiones con consecuencias muy terrenales y que, por tanto, están sujetos a los mismos rigores de control, medición y rendición de cuentas que cualquier otra tecnología crítica.

La encuesta que tiene entre manos es un intento deliberado de domar esa magia con métricas. No pretende disipar el encanto de la IA, sino evitar que se convierta en una fuente de incidentes, sanciones o titulares indeseables. Y, ya que estamos, ayudar a que las inversiones en IA produzcan más valor que sustos.

2. Qué quiere saber realmente la encuesta

La encuesta no se interesa tanto por el modelo preciso que usted usa –sea un GPT, un modelo de visión por computador o una red algo tímida que clasifica documentos– como por el ecosistema en el que vive: quién lo gobierna, qué datos lo alimentan, cómo se despliega, qué se monitoriza y qué se hace cuando algo sale mal. Y, sobre todo, qué indicadores permiten afirmar, sin rubor, que ese conjunto de artefactos merece el adjetivo de “gestionado”.

Cada bloque de preguntas funciona como una linterna sobre una parte del sistema:

- La gobernanza y el alcance del AIMS revelan si la IA se gobierna con la misma seriedad que el resto de la tecnología o si sigue siendo un laboratorio perpetuo.
- El inventario de sistemas de IA responde a la pregunta incómoda de cuántos modelos están realmente en producción –no sólo en presentaciones de PowerPoint.
- La gestión de riesgos y el ciclo de vida de los modelos miden si se trata a la IA como un activo crítico o como un experimento eterno.
- La monitorización, las métricas y los incidentes indican si hay telemetría real o sólo fe.
- Los terceros, la cadena de suministro y la cultura organizativa desvelan hasta qué punto la organización sabe en qué manos está la IA y quién se responsabiliza cuando las cosas se tuercen.

3. El papel de los indicadores en un AIMS sano

ISO/IEC 42001 insiste en que un sistema de gestión de IA no es una colección de políticas sino un ciclo de vida medible: planificar, hacer, verificar, actuar. Esto significa, entre otras cosas, que los indicadores no son decoración ni munición para presentaciones de comité, sino el tejido conectivo que une lo que se pretende con lo que realmente ocurre.

La encuesta, al solicitar información sobre KPIs, telemetría, tiempos de respuesta y análisis de incidentes, persigue tres objetivos discretamente ambiciosos:

- Ver si los indicadores existen más allá de la imaginación de algún documento.
- Comprobar si se revisan con la frecuencia suficiente como para detectar problemas antes de que se conviertan en crisis.
- Evaluar si los datos se utilizan para tomar decisiones incómodas: detener despliegues, reforzar controles, replantear casos de uso.

Si la respuesta sincera a buena parte de estas preguntas es “no”, “a veces” o “depende de quién lo mire”, no pasa nada: precisamente por eso existe la encuesta. El problema no es estar lejos del ideal, sino desconocer la distancia.

4. El Índice Global de Madurez (IGM): una brújula, no un juicio final

El IGM que se deriva de las respuestas pretende ser una brújula, no un veredicto. Una puntuación baja no convierte a una organización en irresponsable por definición; suele indicar que la IA está aún en fase exploratoria o que se han priorizado otros dominios de gestión. Una puntuación alta tampoco garantiza la ausencia de incidentes, pero sí sugiere que, cuando ocurran, habrá menos sorpresas y más capacidad de respuesta.

Los subíndices permiten una lectura más matizada. No es raro encontrar organizaciones con una gobernanza impecable en papel pero una telemetría pobre; o, a la inversa, compañías técnicamente sofisticadas que miden con precisión la deriva de sus modelos pero carecen de una narrativa clara para explicar dichas métricas a la alta dirección. En ambos casos, el IGM sirve como espejo y como excusa para conversaciones que, de otro modo, se aplazarían indefinidamente.

5. El ROI de tomarse en serio la IA segura

Hablar de retorno de inversión en gobierno y seguridad de IA puede sonar tan romántico como calcular el ROI de los cinturones de seguridad. Sin embargo, en un entorno en el que los sistemas de IA pueden afectar a decisiones de crédito, diagnósticos médicos, ciberdefensa o gestión de infraestructuras, no es descabellado preguntarse cuánto cuesta no tener un AIMS razonablemente maduro.

La encuesta ayuda a cuantificar tres tipos de efectos:

- Costes visibles: incidentes, tiempos de caída, sanciones, horas de recuperación.
- Costes invisibles: decisiones erróneas, pérdida de confianza, oportunidades no explotadas por temor a riesgos mal gestionados.
- Beneficios intangibles: capacidad de demostrar diligencia ante reguladores, socios y ciudadanía; mayor margen para innovar sin poner en juego la reputación.

Un ROI bien planteado no promete eliminar los riesgos, sino reducir la frecuencia y la gravedad de los desastres, y aumentar la libertad para usar IA de forma creativa sin que cada nuevo proyecto sea una ruleta rusa.

6. Cómo leer los resultados sin perder la calma

Al recibir el reporte derivado de la encuesta, es tentador enfocarse exclusivamente en la puntuación global. Es más útil empezar por las asimetrías: bloques especialmente débiles, diferencias entre subíndices, áreas donde la organización declara un nivel de madurez alto sin evidencias claras que lo respalden.

Un buen uso de los resultados incluye:

- Contrastar la percepción de diferentes áreas (ej. IA vs. ciberseguridad) sobre las mismas preguntas.
- Identificar “victorias rápidas”: controles o procesos que pueden mejorarse con un esfuerzo razonable y un impacto significativo.
- Señalar temas de discusión para los comités de riesgo y de tecnología, utilizando el lenguaje de indicadores que ISO/IEC 42001 promueve.

La finalidad no es llenar la agenda de tareas imposibles, sino seleccionar cuidadosamente dónde invertir los recursos limitados de talento, tiempo y presupuesto.

7. En resumen: medir para decidir mejor

La encuesta es, en esencia, una invitación a abandonar dos extremos igualmente poco útiles: la fe ciega en la IA como solución milagrosa y la desconfianza absoluta que paraliza cualquier iniciativa. Entre ambos polos se encuentra el territorio de la gestión: el lugar donde se miden las cosas, se aceptan las limitaciones, se corrigen los errores y, con algo de suerte, se aprende.

ISO/IEC 42001 proporciona el marco; esta encuesta propone un conjunto de preguntas para convertir ese marco en conversación concreta, datos accionables y decisiones un poco menos intuitivas y un poco más informadas. Lo demás –la voluntad de responder con honestidad y de actuar en consecuencia– ya no depende de la norma, sino de las personas que la hacen realidad.